

2018-01-16 TRAFFIC ANALYSIS EXERCISE: ANSWERS

"MARS SMART"

<http://www.malware-traffic-analysis.net/2018/01/16/2018-01-16-traffic-analysis-exercise.pcap.zip>

The zip file is password-protected with the standard password. See the "about" page of my site if you don't know it.

YOUR TASK:

Based on the pcap, figure out what online blunder Edward has made. Do a quick incident report that includes the following info:

- Date and start time of the malicious activity in UTC (GMT).
- IP address of the affected Windows host.
- Mac address of the affected Windows host.
- Host name of the affected Windows host.
- User account name on the affected Windows host.
- A short summary of what happened.

ANSWERS:

- Date/Time: 2018-01-16 at approximately 22:32 UTC
- IP address: 10.100.14.173
- Mac address: 08:60:6e:2a:96:f4 (AsustekC_2a:96:f4)
- Host name: MAINE-OFFICE-PC
- User account name: edward.reid
- What happened: Edward's Window's computer was infected with the Nymaim Trojan

DETAILS

As always, I recommend you set up Wireshark according to the tutorials I've documented at:

- <http://malware-traffic-analysis.net/tutorials/index.html>

For details on the infection, see the entries below and look for Nymaim post-infection traffic:

- <http://www.malware-traffic-analysis.net/2017/12/06/index4.html>
- <http://www.malware-traffic-analysis.net/2017/11/03/index2.html>

User account **edward.reid** logged into his Windows client **MAIN-OFFICE-PC** through a domain controller for **marsmart.com**. The associated IP addresses are:

- Windows client (MAIN-OFFICE-PC): 10.100.14.173
- Domain controller for marsmart.com: 10.100.14.22
- Broadcast address for this LAN segment: 10.100.14.255
- Gateway for this LAN segment: 10.100.14.1

2018-01-16 TRAFFIC ANALYSIS EXERCISE: ANSWERS

For Edward's IP address, Mac address, and host name, filter on **nbns** and find your answers as shown in the image below:

Filter: nbns

Date/Time	Src	port	Dst	port	Info
2018-01-16 22:30:28	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<00>
2018-01-16 22:30:28	10.100.14.173	137	10.100.14.255	137	Registration NB MARSMART<00>
2018-01-16 22:30:28	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<20>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<20>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MARSMART<00>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<00>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Name query NB ISATAP<00>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<00>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MARSMART<00>
2018-01-16 22:30:29	10.100.14.173	137	10.100.14.255	137	Registration NB MAINE-OFFICE-PC<20>

Frame 271: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)

- Ethernet II, Src: AsustekC_2a:96:f4 (08:60:6e:2a:96:f4), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
- Internet Protocol Version 4, Src: 10.100.14.173 (10.100.14.173), Dst: 10.100.14.255 (10.100.14.255)
- User Datagram Protocol, Src Port: netbios-ns (137), Dst Port: netbios-ns (137)
- NetBIOS Name Service
 - Transaction ID: 0xffda
 - Flags: 0x2910 (Registration)
 - Questions: 1
 - Answer RRs: 0
 - Authority RRs: 0
 - Additional RRs: 1
 - Queries
 - Additional records
 - MAINE-OFFICE-PC<00>: type NB, class IN
 - Name: MAINE-OFFICE-PC<00> (Workstation/Redirector)
 - Type: NB
 - Class: IN
 - Time to live: 3 days, 11 hours, 20 minutes
 - Data length: 6
 - Name flags: 0x4000(M-node, unique)
 - Addr: 10.100.14.173

The user account name can be found through Kerberos traffic generated when Edward logged into his Windows client. To find the user account name, use the following Wireshark filter:

***kerberos.cname_element and kerberos.KerberosString and
!(kerberos.KerberosString contains \$)***

or use:

kerberos.CNameString and !(kerberos.CNameString contains \$)

The first one works in Wireshark version 1.12, and the second one works in Wireshark 2.2.

2018-01-16 TRAFFIC ANALYSIS EXERCISE: ANSWERS

In the results, work your way down to the **cname** field and find the user account name as shown below:

Filter: **kerberos.cname_element and kerberos.KerberosString** Expression... Clear Apply Save

Date/Time	Src	port	Dst	port	Info
2018-01-16 22:31:33	10.100.14.173	49181	10.100.14.22	88	AS-REQ
2018-01-16 22:31:33	10.100.14.173	49182	10.100.14.22	88	AS-REQ
2018-01-16 22:31:33	10.100.14.22	88	10.100.14.173	49182	AS-REP
2018-01-16 22:31:33	10.100.14.22	88	10.100.14.173	49183	TGS-REP
2018-01-16 22:31:34	10.100.14.22	88	10.100.14.173	49186	TGS-REP
2018-01-16 22:31:34	10.100.14.22	88	10.100.14.173	49188	TGS-REP
2018-01-16 22:31:34	10.100.14.22	88	10.100.14.173	49191	TGS-REP
2018-01-16 22:31:34	10.100.14.22	88	10.100.14.173	49192	TGS-REP

Frame 422: 281 bytes on wire (2248 bits), 281 bytes captured (2248 bits)

Ethernet II, Src: AsustekC_2a:96:f4 (08:60:6e:2a:96:f4), Dst: Dell_7d:94:6e (00:1a:a0:7d:94:6e)

Internet Protocol Version 4, Src: 10.100.14.173 (10.100.14.173), Dst: 10.100.14.22 (10.100.14.22)

Transmission Control Protocol, Src Port: 49181 (49181), Dst Port: kerberos (88), Seq: 1, Ack: 1, Len: 281

Kerberos

- Record Mark: 223 bytes
- as-req
 - pvno: 5
 - msg-type: krb-as-req (10)
 - padata: 1 item
 - req-body
 - Padding: 0
 - kdc-options: 40810010 (forwardable, renewable, canonicalize, renewable-ok)
 - cname**
 - name-type: KRBS-NT-PRINCIPAL (1)
 - name-string: 1 item
 - KerberosString: edward.reid**
 - realm: MARSMART

The following alerts from the Emerging Threats Pro (ETPRO) ruleset triggered on the post-infection traffic:

- **ETPRO TROJAN W32/Nymaim Checkin 6**
- **ETPRO TROJAN Nymaim Checkin 5**

Nymaim post-infection HTTP traffic used various IP addresses based on information retrieved DNS queries using Google DNS (8.8.4.4 and 8.8.8.8) for **dtbgsb.com** and **cedstisond.com**. These DNS results provided IP addresses that the infected host used for HTTP post-infection traffic to **zepter.com** and **carfax.com** (two legitimate domains). However, these are not the actual IP addresses for **zepter.com** and **carfax.com** and those domains are not compromised.

See the next two images for details.

2018-01-16 TRAFFIC ANALYSIS EXERCISE: ANSWERS

RealTime Events Escalated Events								
ST	CNT	Date/Time	Src IP	SPort	Dst IP	DPort	Pr	Event Message
RT	20	2018-01-16...	10.100.14.173	49193	37.143.160.70	80	6	ETPRO TROJAN W32/Nymaim Checkin 6
RT	1	2018-01-16...	37.143.160.70	80	10.100.14.173	49193	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	195.228.41.2	80	10.100.14.173	49195	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	5.56.73.146	80	10.100.14.173	49196	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	81.12.175.59	80	10.100.14.173	49197	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	109.96.148.33	80	10.100.14.173	49198	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	46.29.1.191	80	10.100.14.173	49199	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	84.224.160.159	80	10.100.14.173	49200	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	83.255.177.54	80	10.100.14.173	49201	6	ETPRO TROJAN Nymaim Checkin 5
RT	1	2018-01-16...	41.110.200.194	80	10.100.14.173	49202	6	ETPRO TROJAN Nymaim Checkin 5
RT	2	2018-01-16...	47.89.250.83	80	10.100.14.173	49203	6	ETPRO TROJAN Nymaim Checkin 5

Shown above: Alerts seen using the ETPRO ruleset in Security Onion on Sguil using Suricata.

Filter: (dns and !(ip.addr eq 10.100.14.22) and udp.port eq 53) Expression... Clear Apply Save				
Date/Time	Dst	port	Host	Info
2018-01-16 22:30:34	23.204.108.56	80	www.msftncsi	GET /ncsi.txt HTTP/1.1
2018-01-16 22:32:41	8.8.4.4	53		Standard query 0x0489 A microsoft.com
2018-01-16 22:32:41	10.100.14.173	55800		Standard query response 0x0489 A 23.96.52.53 A 1
2018-01-16 22:32:41	8.8.4.4	53		Standard query 0xb055 A dtybgsb.com
2018-01-16 22:32:41	10.100.14.173	55801		Standard query response 0xb055 A 41.63.181.197 A
2018-01-16 22:32:42	37.143.160.70	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:04	195.228.41.2	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:06	5.56.73.146	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:07	81.12.175.59	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:08	109.96.148.33	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:09	46.29.1.191	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:10	84.224.160.159	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:12	83.255.177.54	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:13	41.110.200.194	80	zepter.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w
2018-01-16 22:33:14	8.8.8.8	53		Standard query 0x4220 A cedstisond.com
2018-01-16 22:33:14	10.100.14.173	55802		Standard query response 0x4220 A 47.89.250.83
2018-01-16 22:33:14	47.89.250.83	80	carfax.com	POST /l5yhus/index.php HTTP/1.1 (application/x-w

Shown above: Traffic shown in Wireshark using the filter (dns and !(ip.addr eq 10.100.14.22) and udp.port eq 53) or http.request

2018-01-16 TRAFFIC ANALYSIS EXERCISE: ANSWERS

BONUS INFORMATION:

The following email and malware were retrieved from VirusTotal Intelligence and used to infect the Windows host for this traffic analysis exercise:

Email: 7b07a0f8fcc6959b9dcd6e668829f1943f57613fe7df5f82cec9ec8b56825aa6

- Date/Time: Tuesday, 2018-01-16 07:59 UTC
- From: Telekom Deutschland GmbH <no-reply@telekom.de>
- Subject: Ihr Anschluss wird am 16.02.2018 gesperrt
- Message-ID: <e99220dab741bd02f755e4865694542a@neptunusworld.com>
- Received: from server.neptunusworld.com ([192.163.206.230]) on 2018-01-16 at 08:02:06 UTC

Attachment: 8afa211e365d1010e7202165b6da7bddb0e0056d1aeb8a62dc9f039b53c6695e

- File name: Erika Schubert 15.01.2018 Telekom.zip
- File size: 420.4 KB (430,508 bytes)
- File type: GZIP compressed data

Extracted EXE: ddf46efeb8349f4bbf2b0c778e7303c5864017577f26686a894c4efffec3f1bb

- File name: Erika Schubert15.01.2018 Telekom.com
- File size: 556.5 KB (569,856 bytes)
- File type: Win32 EXE - PE32 executable for MS Windows (GUI) Intel 80386 32-bit